

Agent Security Compliance Report

CrewAI Framework

Risk Score: **9.8** (HIGH)

COMPLIANCE STATUS: FAIL

54 BLOCK-tier findings require remediation before deployment

Scan Date: 2026-04-06 02:19:53 UTC

Target: crewAI

Scanner Version: agent-audit 0.18.2

Report Generated: 2026-04-06 22:00:01 UTC

Based on OWASP Agentic Security Initiative (ASI) Top 10 — 2026

1. Executive Summary

262 Total Findings	187 Actionable	54 BLOCK Tier	111 WARN Tier	9.8 Risk (HIGH)	1060 Files Scanned
--	--------------------------------------	-------------------------------------	-------------------------------------	---------------------------------------	--

The scan analyzed **1060** files and identified **262** potential security findings, of which **187** are actionable (confidence tier BLOCK, WARN, or INFO). **119** findings are rated **CRITICAL** severity. **133** findings are rated **HIGH** severity. The overall risk score is **9.8** (HIGH).

Compliance Verdict

This codebase **does not meet** agent security compliance requirements. **54** critical findings across **10** OWASP categories require remediation before production deployment. Priority areas: **Tool Misuse, Insecure Inter Agent Comm, Goal Hijack**.

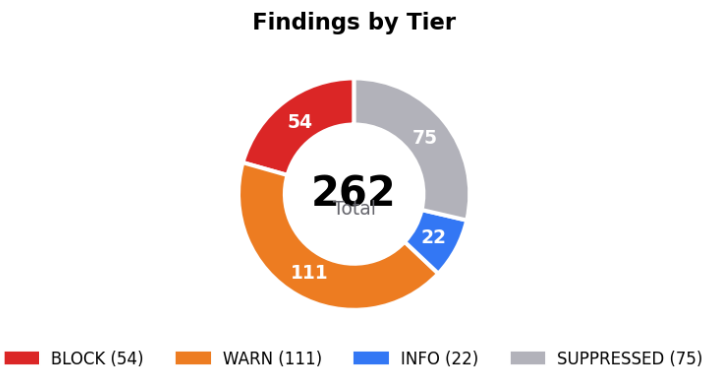
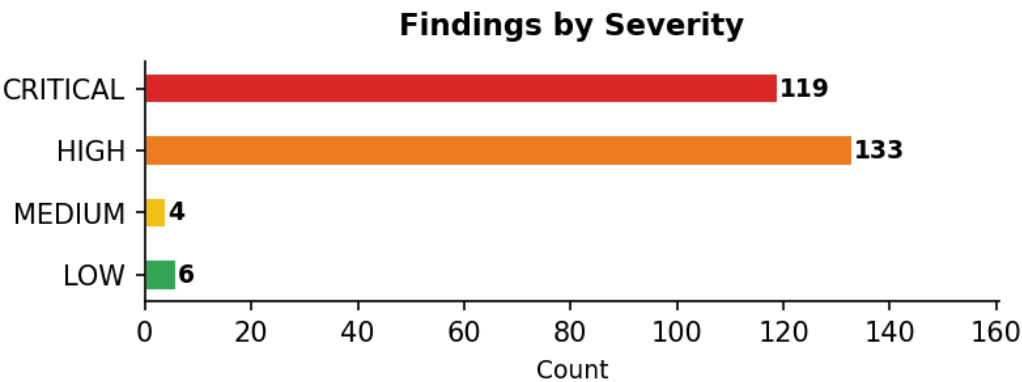
Top Risk Rules

Rule ID	Severity	Count	Impact Summary
AGENT-026	CRITICAL	60	A @tool decorated function accepts string parameters that flow directly to dange...
AGENT-034	HIGH	53	A tool function accepts string or Any parameters without performing input valida...
AGENT-020	HIGH	48	Multi-agent system communicates over unencrypted channels or without mutual auth...

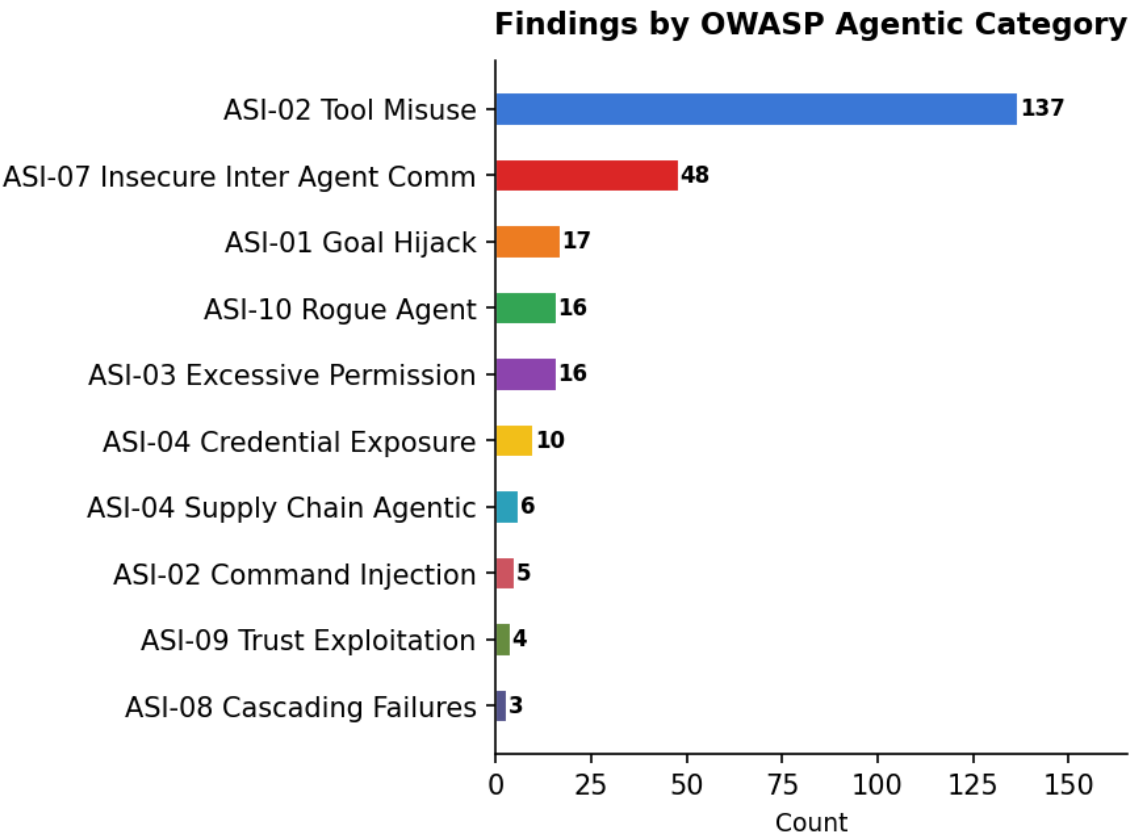
Severity Breakdown

Severity	Count	Percentage
CRITICAL	119	45.4%
HIGH	133	50.8%
MEDIUM	4	1.5%
LOW	6	2.3%

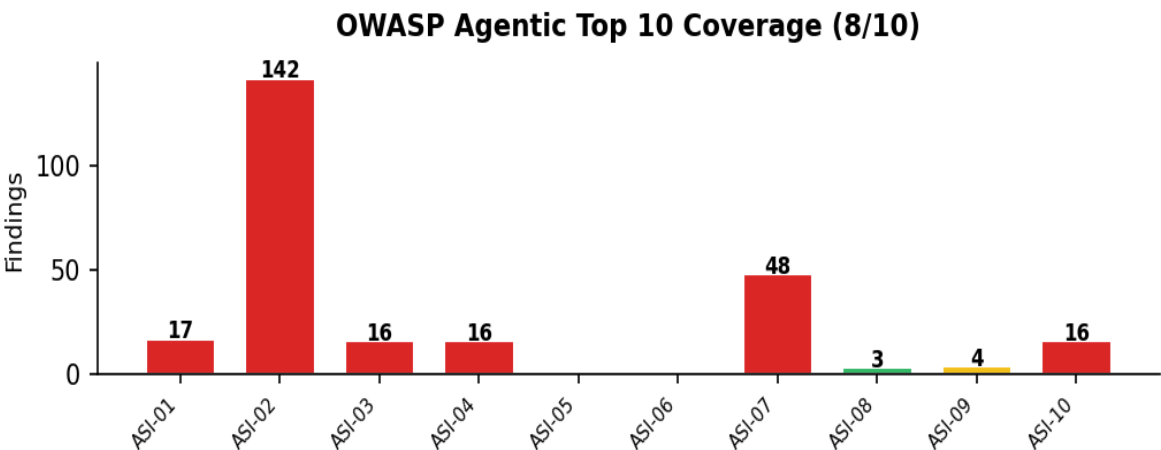
2. Visual Analysis



2b. Category Breakdown



3. OWASP Agentic Top 10 Coverage



ASI ID	Category	Findings	Status
ASI-01	Prompt Injection / Goal Hijack	17	COVERED
ASI-02	Tool Misuse	142	COVERED
ASI-03	Identity & Privilege Abuse	16	COVERED
ASI-04	Supply Chain (Agentic)	16	COVERED
ASI-05	Unexpected Code Execution	0	No findings
ASI-06	Memory Poisoning	0	No findings
ASI-07	Insecure Inter-Agent Communication	48	COVERED
ASI-08	Cascading Failures	3	COVERED
ASI-09	Trust Exploitation	4	COVERED
ASI-10	Rogue Agent	16	COVERED
Total		262	8/10 covered

4. Detailed Findings

AGENT-026 — LangChain Tool Input Not Sanitized [CRITICAL] (60 occurrences)

A @tool decorated function accepts string parameters that flow directly to dangerous operations (file access, command execution, SQL queries, network requests) without input validation or sanitization. This enables Tool Misuse (ASI-02) where attackers can use the tool to perform unauthorized actions.

CWE: CWE-918 | **OWASP:** ASI-02

Remediation: Validate all string inputs in tool functions before passing to dangerous operations. Use allowlists, regex validation, or type checking to ensure inputs are safe.

```
# BAD: Direct execution
@tool
def run_query(query: str) -> str:
    return cursor.execute(query)

# GOOD: With validation
@tool
def run_query(query: str) -> str:
    if not re.match(r"^SELECT ", query, re.IGNORECASE):
        raise ValueError("Only SELECT queries allowed")
    return cursor.execute(query)
```

#	File	Line	Confidence
1	...ols/contextualai_parse_tool/contextual_parse_tool.py	77	0.95
2	...ols/contextualai_parse_tool/contextual_parse_tool.py	86	0.95
3	...ols/contextualai_parse_tool/contextual_parse_tool.py	98	0.95
4	...wai_automation_tool/invoke_crewai_automation_tool.py	149	0.95
5	...ols/src/crewai_tools/tools/brave_search_tool/base.py	191	0.95
6	...crewAI/lib/crewai/src/crewai/a2a/utlis/delegation.py	928	0.85
7	...crewai_platform_tools/crewai_platform_action_tool.py	70	0.70
8	...rewai_platform_tools/crewai_platform_tool_builder.py	47	0.70
9	...i_automation_tool/generate_crewai_automation_tool.py	52	0.70
10	..._eval_tool/patronus_predefined_criteria_eval_tool.py	95	0.70
11	...tools/tools/patronus_eval_tool/patronus_eval_tool.py	146	0.70
12	...s/contextualai_rerank_tool/contextual_rerank_tool.py	69	0.70
13	...ols/tools/scrape_website_tool/scrape_website_tool.py	76	0.70
14	...ols/tools/serply_api_tool/serply_news_search_tool.py	80	0.70
15	...ols/contextualai_query_tool/contextual_query_tool.py	49	0.70
16	...er_scrape_website_tool/serper_scrape_website_tool.py	59	0.70
17	...wai_tools/tools/arxiv_paper_tool/arxiv_paper_tool.py	85	0.70
18	...merge_agent_handler_tool/merge_agent_handler_tool.py	98	0.70
19	...wai_automation_tool/invoke_crewai_automation_tool.py	128	0.70

#	File	Line	Confidence
20	...i_tools/tools/parallel_tools/parallel_search_tool.py	104	0.70
21	...rewai_tools/tools/serper_dev_tool/serper_dev_tool.py	257	0.70
22	...element_from_website/scrape_element_from_website.py	84	0.70
23	...ai_tools/tools/brightdata_tool/brightdata_dataset.py	498	0.70
24	...rewai_tools/tools/brightdata_tool/brightdata_serp.py	228	0.70
25	...i_tools/tools/brightdata_tool/brightdata_unlocker.py	138	0.70
26	...i_tools/tools/brave_search_tool/brave_search_tool.py	136	0.70
27	...jina_scrape_website_tool/jina_scrape_website_tool.py	48	0.70
28	...ai-tools/src/crewai_tools/rag/loaders/docx_loader.py	46	0.70
29	...ools/src/crewai_tools/adapters/enterprise_adapter.py	258	0.70
30	...ools/src/crewai_tools/adapters/enterprise_adapter.py	302	0.70
31	...crewAI/lib/crewai/src/crewai/a2a/utlis/agent_card.py	74	0.65
32	...crewAI/lib/crewai/src/crewai/a2a/utlis/agent_card.py	259	0.65
33	...b/crewai-tools/src/crewai_tools/rag/loaders/utlis.py	37	0.65
34	/tmp/crewAI/lib/crewai/src/crewai/__init__.py	63	0.60
35	/tmp/crewAI/lib/crewai/src/crewai/__init__.py	66	0.60
36	...ai/src/crewai/llms/providers/anthropic/completion.py	196	0.60
37	...ai/src/crewai/llms/providers/anthropic/completion.py	232	0.60
38	...rewai/src/crewai/llms/providers/openai/completion.py	245	0.60
39	...rewai/src/crewai/llms/providers/openai/completion.py	253	0.60
40	/tmp/crewAI/lib/devtools/src/crewai_devtools/cli.py	1166	0.60
41	...wAI/lib/crewai/src/crewai/a2a/auth/server_schemes.py	588	0.45
42	/tmp/crewAI/lib/crewai/src/crewai/cli/plus_api.py	49	0.45
43	/tmp/crewAI/lib/crewai/src/crewai/cli/plus_api.py	65	0.45
44	.../crewAI/lib/crewai/src/crewai/cli/enterprise/main.py	50	0.45
45	...wAI/lib/crewai/src/crewai/cli/authentication/main.py	101	0.45
46	...wAI/lib/crewai/src/crewai/cli/authentication/main.py	133	0.45
47	...AI/lib/crewai-files/src/crewai_files/core/sources.py	478	0.45
48	...AI/lib/crewai-files/src/crewai_files/core/sources.py	490	0.45
49	...tools/src/crewai_tools/rag/loaders/webpage_loader.py	28	0.45
50	...ols/src/crewai_tools/rag/loaders/docs_site_loader.py	29	0.45

#	File	Line	Confidence
51	/tmp/crewAI/lib/crewai/src/crewai/cli/version.py	131	0.20
52	...tools/tools/patronus_eval_tool/patronus_eval_tool.py	39	0.20
53	...tools/tools/patronus_eval_tool/patronus_eval_tool.py	62	0.20
54	...ols/tools/serply_api_tool/serply_news_search_tool.py	67	0.20
55	...s/serply_api_tool/serply_webpage_to_markdown_tool.py	52	0.20
56	...ools/tools/serply_api_tool/serply_web_search_tool.py	86	0.20
57	.../tools/serply_api_tool/serply_scholar_search_tool.py	70	0.20
58	...ools/tools/serply_api_tool/serply_job_search_tool.py	67	0.20
59	...ai-tools/src/crewai_tools/adapters/zapier_adapter.py	45	0.20
60	...ai-tools/src/crewai_tools/adapters/zapier_adapter.py	71	0.20

AGENT-010 — System Prompt Injection Vector in User Input Path [CRITICAL] (16 occurrences)

User-controlled input is concatenated directly into system prompts or agent instructions without sanitization. This enables Agent Goal Hijack (ASI-01) where attackers can redirect the agent's planning and objectives.

CWE: CWE-74 | **OWASP:** ASI-01

Remediation: Never concatenate user input directly into system prompts. Use structured prompt templates with clear separation between system instructions and user data. Implement input validation and sanitization before passing to any prompt template.

```
# BAD: Direct concatenation
prompt = f"You are an agent. User says: {user_input}"

# GOOD: Structured separation
messages = [
    SystemMessage(content="You are a helpful agent."),
    HumanMessage(content=sanitize(user_input))
]
```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/lite_agent.py	818	1.00
2	...i/src/crewai/a2a/extensions/a2ui/client_extension.py	302	1.00
3	...lib/crewai/src/crewai/a2a/extensions/a2ui/prompt.py	47	1.00
4	...lib/crewai/src/crewai/a2a/extensions/a2ui/prompt.py	109	1.00
5	...nt_adapters/langgraph/structured_output_converter.py	56	1.00
6	...nt_adapters/langgraph/structured_output_converter.py	77	1.00
7	...agents/agent_adapters/langgraph/langgraph_adapter.py	148	1.00
8	...dapters/openai_agents/structured_output_converter.py	68	1.00
9	...gents/agent_adapters/openai_agents/openai_adapter.py	94	1.00
10	.../crewAI/lib/crewai/src/crewai/utilities/converter.py	365	1.00

#	File	Line	Confidence
11	.../crewAI/lib/crewai/src/crewai/utilities/converter.py	372	1.00
12	...ai/src/crewai/utilities/evaluators/task_evaluator.py	106	1.00
13	...ai/src/crewai/utilities/evaluators/task_evaluator.py	182	1.00
14	...ewai/src/crewai/llms/providers/bedrock/completion.py	1772	1.00
15	...ai/src/crewai/llms/providers/anthropic/completion.py	652	1.00
16	...rewai/src/crewai/llms/providers/openai/completion.py	635	1.00

AGENT-053 — Agent Self-Modification Risk [CRITICAL] (10 occurrences)

Code writes to Python/code files and/or dynamically loads modified code. This enables agent self-modification attacks where an agent can rewrite its own code or configuration to bypass controls and become a rogue agent (ASI-10). Common patterns include writing user input to .py files and using importlib to reload the modified code.

CWE: CWE-94 | **OWASP:** ASI-10

Remediation: Never allow agent code to modify its own source files or configuration. Use read-only deployment patterns, immutable configuration, and sandboxed execution environments. If dynamic behavior is needed, use declarative configuration with strict validation.

```
# BAD: Agent modifies its own code
def update_config(new_code: str):
    with open("agent_config.py", "w") as f:
        f.write(new_code)
    import importlib
    importlib.reload(agent_config)

# GOOD: Read-only configuration
def update_config(config_dict: dict):
    validate_config(config_dict) # Strict validation
    # Store in database, not file
    db.save_config(config_dict)
```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	301	1.00
2	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	307	1.00
3	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	311	1.00
4	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	455	1.00
5	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	461	1.00
6	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	465	1.00
7	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	595	1.00
8	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	600	1.00
9	/tmp/crewAI/lib/crewai/src/crewai/cli/utlis.py	604	1.00
10	...tools/code_interpreter_tool/code_interpreter_tool.py	115	1.00

AGENT-041 — SQL Injection via String Interpolation [CRITICAL] (9 occurrences)

SQL queries are constructed using f-strings, .format(), string concatenation, or % formatting instead of parameterized queries. This allows SQL injection attacks through user-controlled input.

CWE: CWE-89 | OWASP: ASI-02

Remediation: Use parameterized queries instead of string interpolation. Pass user input as separate parameters, not as part of the SQL string.

```
# BAD: SQL injection vulnerable
cursor.execute(f"SELECT * FROM users WHERE id = '{user_id}'")
cursor.execute("SELECT * FROM users WHERE id = %s" % user_id)

# GOOD: Parameterized query
cursor.execute("SELECT * FROM users WHERE id = ?", (user_id,))
cursor.execute("SELECT * FROM users WHERE id = %s", (user_id,))
```

#	File	Line	Confidence
1	...ai-tools/tests/tools/singlestore_search_tool_test.py	37	1.00
2	...tools/snowflake_search_tool/snowflake_search_tool.py	218	1.00
3	...s/singlestore_search_tool/singlestore_search_tool.py	419	1.00
4	/tmp/crewAI/lib/crewai/tests/a2a/utlis/test_task.py	162	0.25
5	/tmp/crewAI/lib/crewai/tests/a2a/utlis/test_task.py	181	0.25
6	/tmp/crewAI/lib/crewai/tests/a2a/utlis/test_task.py	203	0.25
7	/tmp/crewAI/lib/crewai/tests/a2a/utlis/test_task.py	228	0.25
8	/tmp/crewAI/lib/crewai/tests/a2a/utlis/test_task.py	252	0.25
9	/tmp/crewAI/lib/crewai/tests/a2a/utlis/test_task.py	368	0.25

AGENT-004 — Hardcoded Credentials [CRITICAL] (9 occurrences)

Found Private Key Header

CWE: CWE-798 | OWASP: ASI-04

Remediation: Use environment variables or a secrets manager

#	File	Line	Confidence
1	...ib/crewai/src/crewai/a2a/utlis/agent_card_signing.py	106	0.98
2	/tmp/crewAI/.env.test	89	0.70
3	/tmp/crewAI/.env.test	115	0.70
4	...s/src/crewai_tools/tools/mysql_search_tool/README.md	20	0.70
5	...tools/src/crewai_tools/tools/weaviate_tool/README.md	26	0.70
6	...tools/src/crewai_tools/tools/weaviate_tool/README.md	38	0.70
7	...ools/src/crewai_tools/tools/stagehand_tool/README.md	50	0.70
8	...ools/src/crewai_tools/tools/stagehand_tool/README.md	90	0.70
9	...ools/src/crewai_tools/tools/stagehand_tool/README.md	229	0.70

AGENT-112 — Sub-Agent Spawn Without Permission Boundary [CRITICAL] (5 occurrences)

An agent spawns child agents or sub-agents while passing the parent's full tool set, credentials, or permissions without restriction. This violates the principle of least privilege and allows sub-agents to perform actions beyond their intended scope.

CWE: CWE-250 | OWASP: ASI-03

Remediation: Implement explicit permission scoping for sub-agents. Pass only the minimum required tools and permissions using allowlists. Never inherit full parent capabilities.

```
# BAD: Sub-agent inherits all parent tools
child = Agent(tools=self.tools, name="researcher")

# GOOD: Explicit minimal tool allowlist
child = Agent(
    tools=[search_tool, read_tool], # Only what's needed
    name="researcher"
)
```

#	File	Line	Confidence
1	...agents/agent_adapters/langgraph/langgraph_adapter.py	195	0.90
2	...gents/agent_adapters/openai_agents/openai_adapter.py	141	0.90
3	/tmp/crewAI/lib/crewai/src/crewai/agent/core.py	740	0.90
4	/tmp/crewAI/lib/crewai/src/crewai/agent/core.py	865	0.90
5	/tmp/crewAI/lib/crewai/tests/agents/test_lite_agent.py	293	0.23

AGENT-001 — Command Injection via Unsanitized Input [CRITICAL] (5 occurrences)

Tool accepts user input passed directly to shell execution without proper sanitization.

CWE: CWE-78 | OWASP: ASI-02

Remediation: Use shlex.quote() to escape user input, use argument lists instead of shell strings, implement a command allowlist.

```
# Safe: use argument list
subprocess.run(["ls", shlex.quote(user_input)])
```

#	File	Line	Confidence
1	...tools/code_interpreter_tool/code_interpreter_tool.py	142	0.58
2	...tools/code_interpreter_tool/code_interpreter_tool.py	421	0.58
3	/tmp/crewAI/lib/crewai/tests/agents/test_lite_agent.py	59	0.20
4	...lib/crewai/tests/agents/test_native_tool_calling.py	44	0.20
5	...rewAI/lib/crewai/tests/utilities/test_agent_utils.py	41	0.20

AGENT-118 — Human-in-the-Loop Bypass in Agent Execution Chain [CRITICAL] (4 occurrences)

Agent execution chains where human approval checkpoints can be bypassed through agent self-modification, tool chaining, or delegation. Agents that can modify their own approval settings at runtime, or delegation chains that accumulate permissions beyond what any single agent was granted, undermine human oversight guarantees.

CWE: CWE-862 | OWASP: ASI-09

Remediation: Make approval settings immutable after initialization. Implement permission attenuation (not amplification) in delegation chains. Ensure delegated agents always have equal or fewer permissions.

```
# BAD: Mutable approval settings
class MyAgent(Agent):
    def escalate(self):
        self.human_input_mode = "NEVER" # Bypasses HITL
        self.delegate(task, target_agent)

# GOOD: Immutable approval with attenuation
```

```

class MyAgent(Agent):
    def __init__(self, **kwargs):
        super().__init__(**kwargs)
        self._frozen = True

    def __setattr__(self, name, value):
        if getattr(self, '_frozen', False) and name == 'human_input_mode':
            raise AttributeError("Cannot modify approval settings after init")
        super().__setattr__(name, value)

```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/crew.py	1213	0.85
2	/tmp/crewAI/lib/crewai/tests/test_crew.py	770	0.21
3	/tmp/crewAI/lib/crewai/tests/test_crew.py	2948	0.21
4	/tmp/crewAI/lib/crewai/tests/test_crew.py	2949	0.21

AGENT-024 — Agent Without Kill Switch / Shutdown Mechanism [CRITICAL] (3 occurrences)

Agent operates without a kill switch or graceful shutdown mechanism. If the agent drifts from its intended purpose, there is no way to immediately halt its execution (ASI-10).

CWE: CWE-441 | **OWASP:** ASI-10

Remediation: Implement a non-negotiable, auditable kill switch for all agents. Set `max_iterations` and `max_execution_time`. For long-running agents, implement heartbeat monitoring and automatic shutdown on anomaly.

```

# GOOD: Agent with kill switch
agent = AgentExecutor(
    agent=agent, tools=tools,
    max_iterations=25,
    max_execution_time=600,
    early_stopping_method="generate",
    callbacks=[KillSwitchCallback(max_cost=10.0)],
)

```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/crew.py	1778	1.00
2	...agents/agent_adapters/langgraph/langgraph_adapter.py	124	1.00
3	...agents/agent_adapters/langgraph/langgraph_adapter.py	132	1.00

AGENT-117 — Automatic Tool Permission Approval Without Safety Classification [CRITICAL] (3 occurrences)

Agent configuration auto-approves tool executions without any safety classification or risk assessment. This bypasses the principle of human oversight and allows agents to execute dangerous operations (file writes, shell commands, network requests) without confirmation.

CWE: CWE-862 | **OWASP:** ASI-03

Remediation: Implement tiered tool approval. Classify tools by risk level (read-only vs write vs execute). Require human confirmation for high-risk tool invocations. Never combine auto-approval with code execution.

```

# BAD: Auto-approve everything
agent = AssistantAgent(
    human_input_mode="NEVER",
    code_execution_config={"use_docker": False}
)

# GOOD: Tiered approval with sandboxing
agent = AssistantAgent(

```

```

human_input_mode="TERMINATE", # Ask before terminating
code_execution_config={
  "use_docker": True, # Sandboxed execution
  "timeout": 60
}
)

```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/tests/test_crew.py	1622	0.22
2	/tmp/crewAI/lib/crewai/tests/test_crew.py	3872	0.22
3	/tmp/crewAI/lib/crewai/tests/test_crew.py	3881	0.22

AGENT-034 — Tool Function Without Input Validation [HIGH] (53 occurrences)

A tool function accepts string or Any parameters without performing input validation in the function body. This enables tool misuse where attackers can pass malicious inputs to trigger unauthorized actions.

CWE: CWE-20 | **OWASP:** ASI-02

Remediation: Add input validation at the start of tool functions. Use isinstance() checks, regex validation, or pydantic Field constraints to ensure inputs are safe before processing.

```

# BAD: No validation
@tool
def run_query(query: str) -> str:
    return cursor.execute(query)

# GOOD: With validation
@tool
def run_query(query: str) -> str:
    if not isinstance(query, str) or len(query) > 1000:
        raise ValueError("Invalid query")
    if not re.match(r"^SELECT ", query, re.IGNORECASE):
        raise ValueError("Only SELECT queries allowed")
    return cursor.execute(query)

```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/cli/tools/main.py	135	0.95
2	/tmp/crewAI/lib/crewai/src/crewai/cli/tools/main.py	254	0.95
3	...tools/code_interpreter_tool/code_interpreter_tool.py	115	0.95
4	...tools/code_interpreter_tool/code_interpreter_tool.py	391	0.95
5	...tools/code_interpreter_tool/code_interpreter_tool.py	414	0.95
6	/tmp/crewAI/lib/devtools/src/crewai_devtools/cli.py	44	0.95
7	/tmp/crewAI/lib/crewai/src/crewai/cli/run_crew.py	61	0.85
8	/tmp/crewAI/lib/crewai/src/crewai/cli/cli.py	64	0.85
9	/tmp/crewAI/lib/crewai/src/crewai/agent/core.py	1227	0.75
10	/tmp/crewAI/lib/crewai/src/crewai/cli/tools/main.py	71	0.75
11	...h_scraper_tool/oxylabs_amazon_search_scraper_tool.py	129	0.75
12	...ls/tools/mongodb_vector_search_tool/vector_search.py	118	0.75

#	File	Line	Confidence
13	..._scrape_website_tool/scrapfly_scrape_website_tool.py	59	0.75
14	...tools/snowflake_search_tool/snowflake_search_tool.py	140	0.75
15	.../patronus_eval_tool/patronus_local_evaluator_tool.py	72	0.75
16	...s/singlestore_search_tool/singlestore_search_tool.py	201	0.75
17	...tools/browserbase_load_tool/browserbase_load_tool.py	62	0.75
18	...ools/qdrant_vector_search_tool/qdrant_search_tool.py	114	0.75
19	.../crewai_tools/tools/couchbase_tool/couchbase_tool.py	183	0.75
20	...crewai_tools/tools/serpapi_tool/serpapi_base_tool.py	38	0.75
21	.../src/crewai_tools/tools/multion_tool/multion_tool.py	45	0.75
22	...ersal_scraper_tool/oxylabs_universal_scraper_tool.py	123	0.75
23	.../src/crewai_tools/tools/linkup/linkup_search_tool.py	46	0.75
24	...ols/selenium_scraping_tool/selenium_scraping_tool.py	90	0.75
25	...tools/code_interpreter_tool/code_interpreter_tool.py	286	0.75
26	...scrape_website_tool/firecrawl_scrape_website_tool.py	94	0.75
27	...rc/crewai_tools/tools/weaviate_tool/vector_search.py	99	0.75
28	.../src/crewai_tools/tools/extra_tools/extra_search_tool.py	89	0.75
29	...l_crawl_website_tool/firecrawl_crawl_website_tool.py	94	0.75
30	...tools/tavily_extractor_tool/tavily_extractor_tool.py	109	0.75
31	...ls/src/crewai_tools/tools/spider_tool/spider_tool.py	107	0.75
32	...s/scrapegraph_scrape_tool/scrapegraph_scrape_tool.py	102	0.75
33	...tools/tools/tavily_search_tool/tavily_search_tool.py	137	0.75
34	..._scraper_tool/oxylabs_amazon_product_scraper_tool.py	127	0.75
35	...h_scraper_tool/oxylabs_google_search_scraper_tool.py	132	0.75
36	...tools/firecrawl_search_tool/firecrawl_search_tool.py	95	0.75
37	/tmp/crewAI/lib/crewai/src/crewai/cli/evaluate_crew.py	20	0.65
38	...crewAI/lib/crewai/src/crewai/cli/replay_from_task.py	16	0.65
39	/tmp/crewAI/lib/crewai/src/crewai/cli/train_crew.py	22	0.65
40	/tmp/crewAI/lib/crewai/src/crewai/cli/kickoff_flow.py	13	0.65
41	/tmp/crewAI/lib/crewai/src/crewai/cli/plot_flow.py	13	0.65
42	/tmp/crewAI/lib/crewai/src/crewai/cli/triggers/main.py	129	0.65
43	.../crewai/src/crewai/events/listeners/tracing/utils.py	230	0.65

#	File	Line	Confidence
44	.../crewai/src/crewai/events/listeners/tracing/utils.py	249	0.65
45	...rewAI/lib/devtools/src/crewai_devtools/docs_check.py	156	0.65
46	/tmp/crewAI/lib/devtools/src/crewai_devtools/cli.py	77	0.65
47	/tmp/crewAI/lib/devtools/src/crewai_devtools/cli.py	85	0.65
48	/tmp/crewAI/lib/crewai/src/crewai/cli/install_crew.py	25	0.60
49	/tmp/crewAI/lib/crewai/src/crewai/cli/git.py	33	0.50
50	/tmp/crewAI/lib/crewai/src/crewai/cli/git.py	37	0.50
51	/tmp/crewAI/lib/crewai/src/crewai/cli/git.py	51	0.50
52	/tmp/crewAI/lib/crewai/src/crewai/cli/git.py	80	0.50
53	...lib/crewai-tools/tests/test_optional_dependencies.py	31	0.19

AGENT-020 — Unencrypted or Unauthenticated Inter-Agent Channel [HIGH] (48 occurrences)

Multi-agent system communicates over unencrypted channels or without mutual authentication. Agents trust other agents based on network location alone, enabling impersonation and message tampering (ASI-07).

CWE: CWE-311 | **OWASP:** ASI-07

Remediation: Apply mutual TLS (mTLS) to all inter-agent communication. Cryptographically sign all messages between agents. Never trust agent identity based on network location alone.

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/crew.py	1778	1.00
2	...i/rag/embeddings/providers/ollama/ollama_provider.py	17	0.05
3	...rewai/llms/providers/openai_compatible/completion.py	59	0.05
4	...rewai/llms/providers/openai_compatible/completion.py	66	0.05
5	...rewai/llms/providers/openai_compatible/completion.py	73	0.05
6	...i-tools/tests/tools/merge_agent_handler_tool_test.py	104	0.05
7	...i-tools/tests/tools/merge_agent_handler_tool_test.py	251	0.05
8	...i-tools/tests/tools/merge_agent_handler_tool_test.py	305	0.05
9	...crewAI/lib/crewai/tests/a2a/utils/test_agent_card.py	33	0.03
10	...crewAI/lib/crewai/tests/a2a/utils/test_agent_card.py	55	0.03
11	...crewAI/lib/crewai/tests/a2a/utils/test_agent_card.py	155	0.03
12	...crewAI/lib/crewai/tests/a2a/utils/test_agent_card.py	168	0.03
13	...l/lib/crewai/tests/agents/test_agent_a2a_wrapping.py	36	0.03
14	...l/lib/crewai/tests/agents/test_agent_a2a_wrapping.py	55	0.03

#	File	Line	Confidence
15	...l/lib/crewai/tests/agents/test_agent_a2a_wrapping.py	101	0.03
16	...AI/lib/crewai/tests/agents/test_agent_a2a_kickoff.py	137	0.03
17	...wai/tests/agents/test_a2a_trust_completion_status.py	34	0.03
18	...wai/tests/agents/test_a2a_trust_completion_status.py	89	0.03
19	...wai/tests/agents/test_a2a_trust_completion_status.py	151	0.03
20	.../crewAI/lib/crewai/tests/a2a/test_a2a_integration.py	16	0.00
21	.../crewAI/lib/crewai/tests/a2a/test_a2a_integration.py	153	0.00
22	.../crewAI/lib/crewai/tests/a2a/test_a2a_integration.py	207	0.00
23	.../crewAI/lib/crewai/tests/a2a/test_a2a_integration.py	270	0.00
24	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	90	0.00
25	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	103	0.00
26	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	116	0.00
27	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	129	0.00
28	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	142	0.00
29	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	181	0.00
30	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	203	0.00
31	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	218	0.00
32	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	231	0.00
33	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	248	0.00
34	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	269	0.00
35	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	288	0.00
36	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	304	0.00
37	...crewAI/lib/crewai/tests/a2a/utlis/test_agent_card.py	320	0.00
38	/tmp/crewAI/lib/crewai/tests/agents/test_agent.py	1361	0.00
39	/tmp/crewAI/lib/crewai/tests/agents/test_agent.py	1379	0.00
40	/tmp/crewAI/lib/crewai/tests/agents/test_agent.py	1490	0.00
41	...AI/lib/crewai/tests/agents/test_agent_a2a_kickoff.py	13	0.00
42	/tmp/crewAI/lib/crewai/tests/mcp/test_sse_transport.py	14	0.00
43	.../tests/rag/embeddings/test_backward_compatibility.py	279	0.00
44	.../crewAI/lib/crewai/tests/utilities/test_converter.py	230	0.00
45	...sts/lms/openai_compatible/test_openai_compatible.py	104	0.00

#	File	Line	Confidence
46	...sts/llms/openai_compatible/test_openai_compatible.py	108	0.00
47	...sts/llms/openai_compatible/test_openai_compatible.py	112	0.00
48	...sts/llms/openai_compatible/test_openai_compatible.py	116	0.00

AGENT-047 — Subprocess Execution Without Sandbox [HIGH] (15 occurrences)

Agent executes subprocess (subprocess.run) without sandbox isolation. Subprocess execution with dynamic input can lead to command injection.

CWE: CWE-78 | **OWASP:** ASI-02

Remediation: Avoid shell=True. Use parameterized commands with shlex.quote(). Consider sandboxing subprocess execution with containers or restricted shells.

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/cli/run_crew.py	61	0.80
2	/tmp/crewAI/lib/crewai/src/crewai/cli/evaluate_crew.py	20	0.80
3	...crewAI/lib/crewai/src/crewai/cli/replay_from_task.py	16	0.80
4	/tmp/crewAI/lib/crewai/src/crewai/cli/train_crew.py	22	0.80
5	/tmp/crewAI/lib/crewai/src/crewai/cli/install_crew.py	25	0.80
6	/tmp/crewAI/lib/crewai/src/crewai/cli/kickoff_flow.py	13	0.80
7	/tmp/crewAI/lib/crewai/src/crewai/cli/plot_flow.py	13	0.80
8	/tmp/crewAI/lib/devtools/src/crewai_devtools/cli.py	44	0.80
9	/tmp/crewAI/lib/crewai/src/crewai/agent/core.py	1227	0.48
10	.../crewai/src/crewai/events/listeners/tracing/utils.py	230	0.48
11	.../crewai/src/crewai/events/listeners/tracing/utils.py	249	0.48
12	/tmp/crewAI/lib/devtools/src/crewai_devtools/cli.py	77	0.48
13	/tmp/crewAI/lib/devtools/src/crewai_devtools/cli.py	85	0.48
14	/tmp/crewAI/lib/crewai/src/crewai/cli/tools/main.py	254	0.40
15	...lib/crewai-tools/tests/test_optional_dependencies.py	31	0.12

AGENT-115 — Agent Background Daemon Without Lifecycle Control [HIGH] (6 occurrences)

An agent process runs as a background daemon or service without TTL (time-to-live), heartbeat checks, or graceful shutdown mechanisms. Uncontrolled agent daemons consume resources indefinitely and can persist malicious behavior beyond intended session boundaries.

CWE: CWE-400 | **OWASP:** ASI-03

Remediation: Implement TTL-based lifecycle management. Add heartbeat checks, graceful shutdown handlers (SIGTERM), and maximum session duration limits. Use a multi-gate trigger pattern for daemon activation.

```
# BAD: Daemon without lifecycle control
thread = Thread(target=agent_loop, daemon=True)
thread.start()
```

```

def agent_loop():
while True:
process_tasks()

# GOOD: Daemon with TTL and graceful shutdown
import signal

class AgentDaemon:
def __init__(self, ttl_seconds=86400):
self.ttl = ttl_seconds
self.start_time = time.time()
self.running = True
signal.signal(signal.SIGTERM, self.shutdown)

def shutdown(self, signum, frame):
self.running = False

def run(self):
while self.running:
if time.time() - self.start_time > self.ttl:
break
process_tasks()

```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/task.py	548	0.85
2	/tmp/crewAI/lib/crewai/src/crewai/__init__.py	76	0.85
3	.../crewai/src/crewai/memory/storage/lancedb_storage.py	219	0.85
4	.../crewAI/lib/crewai/src/crewai/utilities/streaming.py	247	0.85
5	/tmp/crewAI/lib/crewai/src/crewai/events/event_bus.py	145	0.85
6	...lib/crewai/src/crewai/a2a/updates/polling/handler.py	84	0.80

AGENT-021 — Missing Circuit Breaker / Max Iterations [HIGH] (3 occurrences)

Agent loop lacks circuit breaker, max iteration limit, or error budget. A minor tool failure can trigger infinite retry loops or increasingly destructive recovery attempts (ASI-08).

CWE: CWE-754 | **OWASP:** ASI-08

Remediation: Always configure `max_iterations`, `max_execution_time`, and error budgets for agent loops. Implement circuit breaker patterns that pause execution and seek human intervention on repeated failures.

```

# BAD: No limits
agent = AgentExecutor(agent=agent, tools=tools)

# GOOD: Explicit limits
agent = AgentExecutor(
agent=agent, tools=tools,
max_iterations=15,
max_execution_time=300,
handle_parsing_errors=True,
early_stopping_method="generate",
)

```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/crew.py	1778	1.00
2	...agents/agent_adapters/langgraph/langgraph_adapter.py	124	1.00
3	...agents/agent_adapters/langgraph/langgraph_adapter.py	132	1.00

AGENT-025 — Agent Without Behavioral Monitoring / Logging [HIGH] (3 occurrences)

Agent actions are not logged or monitored, making it impossible to detect behavioral drift or misaligned actions. Without observability, rogue behavior goes undetected (ASI-10).

CWE: CWE-441 | **OWASP:** ASI-10

Remediation: Implement comprehensive logging of every agent decision, tool call, and state change. Establish behavioral baselines and alert on deviations. Use tracing tools like LangSmith or custom callbacks for full observability.

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/crew.py	1778	1.00
2	...agents/agent_adapters/langgraph/langgraph_adapter.py	124	1.00
3	...agents/agent_adapters/langgraph/langgraph_adapter.py	132	1.00

AGENT-050 — LangChain AgentExecutor Without Safety Parameters [HIGH] (1 occurrences)

AgentExecutor or create_react_agent is instantiated without proper safety parameters (max_iterations, max_execution_time). Without these limits, the agent may run indefinitely or be manipulated into excessive iterations through goal hijacking (ASI-01).

CWE: CWE-400 | **OWASP:** ASI-01

Remediation: Always configure max_iterations and max_execution_time for AgentExecutor to prevent unbounded execution. Set reasonable limits based on expected task complexity.

```
# BAD: No limits
executor = AgentExecutor(agent=agent, tools=tools, verbose=True)

# GOOD: With safety limits
executor = AgentExecutor(
    agent=agent,
    tools=tools,
    max_iterations=10,
    max_execution_time=60,
    handle_parsing_errors=True,
)
```

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/src/crewai/agent/core.py	1383	1.00

AGENT-002 — Excessive Agent Permissions [MEDIUM] (2 occurrences)

Agent has 17 tools configured, which may be excessive

CWE: CWE-250

Remediation: Consider splitting into multiple specialized agents

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/tests/tools/test_base_tool.py	1	0.70
2	/tmp/crewAI/lib/crewai/tests/agents/test_agent.py	1	0.70

AGENT-111 — Internal Hostname Exposed in Code [MEDIUM] (1 occurrences)

Internal hostname 'crewai.agent.internal.meta' found in source code. This may expose internal infrastructure details in published packages.

CWE: CWE-200 | **OWASP:** ASI-04

Remediation: Replace internal hostnames with environment variables or configuration values. Use os.environ.get() or a config loader.

#	File	Line	Confidence
1	...crewai/src/crewai/agents/agent_builder/base_agent.py	26	0.75

AGENT-110 — Debug Artifact Not Excluded from Distribution [LOW] (6 occurrences)

pyproject.toml does not exclude *.map files from distribution. Source maps may leak internal code structure in published packages.

CWE: CWE-540 | **OWASP:** ASI-04

Remediation: Add '*.map' to the exclude patterns in your build tool configuration (e.g., [tool.setuptools.packages.find] exclude or [tool.poetry] exclude).

#	File	Line	Confidence
1	/tmp/crewAI/lib/crewai/pyproject.toml	1	0.60
2	.../crewai/src/crewai/cli/templates/crew/pyproject.toml	1	0.60
3	.../crewai/src/crewai/cli/templates/flow/pyproject.toml	1	0.60
4	/tmp/crewAI/lib/crewai-files/pyproject.toml	1	0.60
5	/tmp/crewAI/lib/crewai-tools/pyproject.toml	1	0.60
6	/tmp/crewAI/lib/devtools/pyproject.toml	1	0.60

5. Remediation Roadmap

Prioritized remediation plan based on severity and occurrence count.

Priorit y	Rule ID	Title	Severity	Count	Est. Effort
P1	AGENT-010	System Prompt Injection Vector in User I...	CRITICAL	16	High (Architecture Change)
P2	AGENT-041	SQL Injection via String Interpolation	CRITICAL	9	High (Architecture Change)
P3	AGENT-053	Agent Self-Modification Risk	CRITICAL	10	High (Architecture Change)
P4	AGENT-004	Hardcoded Credentials	CRITICAL	9	High (Architecture Change)
P5	AGENT-026	LangChain Tool Input Not Sanitized	CRITICAL	60	High (Architecture Change)
P6	AGENT-112	Sub-Agent Spawn Without Permission Bound...	CRITICAL	5	High (Architecture Change)
P7	AGENT-001	Command Injection via Unsanitized Input	CRITICAL	5	High (Architecture Change)
P8	AGENT-024	Agent Without Kill Switch / Shutdown Mec...	CRITICAL	3	Medium (Code Refactor)
P9	AGENT-118	Human-in-the-Loop Bypass in Agent Execut...	CRITICAL	4	Medium (Code Refactor)
P10	AGENT-117	Automatic Tool Permission Approval Witho...	CRITICAL	3	Medium (Code Refactor)
P11	AGENT-020	Unencrypted or Unauthenticated Inter-Age...	HIGH	48	Medium (Systematic Fix)
P12	AGENT-034	Tool Function Without Input Validation	HIGH	53	Medium (Systematic Fix)
P13	AGENT-047	Subprocess Execution Without Sandbox	HIGH	15	Medium (Systematic Fix)
P14	AGENT-021	Missing Circuit Breaker / Max Iterations	HIGH	3	Low (Targeted Fix)
P15	AGENT-025	Agent Without Behavioral Monitoring / Lo...	HIGH	3	Low (Targeted Fix)
P16	AGENT-050	LangChain AgentExecutor Without Safety P...	HIGH	1	Low (Targeted Fix)
P17	AGENT-115	Agent Background Daemon Without Lifecycl...	HIGH	6	Low (Targeted Fix)
P18	AGENT-111	Internal Hostname Exposed in Code	MEDIUM	1	Low (Targeted Fix)
P19	AGENT-002	Excessive Agent Permissions	MEDIUM	2	Low (Targeted Fix)
P20	AGENT-110	Debug Artifact Not Excluded from Distrib...	LOW	6	Low (Targeted Fix)

6. Methodology

This report was generated by **agent-audit v0.18.2**, a static security analyzer for AI agent code, MCP configurations, and agentic workflows.

Analysis Techniques

- **AST-based taint analysis** — Tracks data flow from user inputs through tool functions to dangerous sinks (subprocess, eval, SQL).
- **Credential detection** — Three-stage pipeline: regex matching, value entropy analysis, and contextual confidence scoring.
- **MCP configuration audit** — Validates Model Context Protocol server configs for SSRF, credential exposure, and scope issues.
- **Framework-aware analysis** — Reduces false positives by recognizing Pydantic schemas, LangChain/CrewAI internals, and test fixtures.

Confidence Scoring

Each finding receives a confidence score (0.0 — 1.0) computed from pattern specificity, context multipliers (test/infra dampening), and taint flow analysis. Scores map to actionability tiers:

Tier	Threshold	Meaning
BLOCK	>= 0.92	High confidence — should fail CI
WARN	>= 0.60	Medium confidence — review recommended
INFO	>= 0.30	Low confidence — informational
SUPPRESSED	< 0.30	Very low — hidden by default

Standards Alignment

All rules are mapped to OWASP Agentic Security Initiative (ASI) Top 10 categories and MITRE CWE identifiers. The scanner provides 10/10 coverage of the OWASP ASI Top 10.

Limitations

This is a **static analysis** report. It does not execute agent code or test runtime behavior. Some findings may be false positives due to static analysis limitations. Manual review is recommended for all BLOCK-tier findings before taking remediation action.